

SILENT SHIFT

Detecting the Insider Before the Incident

COMPLETE IDEA SPECIFICATION — v2

Updated: deployment model, data governance, honest limitations, refined business model

MIT Hackathon · Problem Statement 16 · Peace, Justice and Strong Institutions

Prepared by Mohammed Shamaz

September 12, 2026

Contents

1. Executive Summary
2. Official Problem Statement & Requirement Coverage
3. Core Design Philosophy
4. Data Strategy
5. Deployment Model — Where It Lives
6. System Architecture
7. Models & Techniques
8. Handling Legitimate Context Changes
9. Controlling False Positives
10. Data Governance & Responsible Use
11. Investigator Experience & Demo Walkthrough
12. Known Limitations & Residual Risks
13. Technology Stack
14. Business Model
15. Build Roadmap (Hackathon Timeline)
16. Pre-Submission Checklist
17. Why This Approach Wins
18. Future Roadmap (Beyond the Hackathon)
19. Research Basis & References

1. Executive Summary

Silent Shift is a behavioral security system that detects insider threats by scoring every user against two independent baselines at once — their own historical behavior, and the behavior of their peer cohort (same role, team, or manager) — rather than a single self-comparison, which is the most common and weakest design in both commercial UEBA tools and the published literature.

Role, team, manager, and tenure are treated as live, continuously refreshed inputs. A legitimate change — a new project, a promotion, a team transfer — updates a user's peer cohort immediately and does not itself trigger a false alarm, without model retraining. An explicit statistical drift test (CUSUM) runs over each user's daily risk score, catching a slow, sustained behavioral shift even when no single day looks alarming — directly answering the brief's framing of threats that emerge "gradually or suddenly."

Architecturally, Silent Shift is a passive analytics layer, not an inline proxy or a blocking system. It never intercepts, modifies, or delays anything, and nothing is installed on any employee's device — it reads logs that a company's existing systems already generate, on a backend server IT controls. It never takes automatic action against a user; every flagged case is routed to a human investigator, who decides what happens next.

Every alert is delivered with a plain-English explanation built from the same signals that produced the score, and an analyst feedback control down-weights confirmed false positives going forward. The system is trained and demonstrated on the CERT Insider Threat Dataset — a real, published benchmark — and its core design choices are drawn from a production system Google has run since 2018 (Facade), from peer-reviewed ensemble research, and from documented practitioner data on UEBA false-positive fatigue.

This version of the specification also documents, openly, what the system does not yet do. A security tool is judged as much by what it honestly acknowledges as a limitation as by what it claims to solve — Section 12 states these plainly rather than leaving them to be discovered under questioning.

2. Official Problem Statement & Requirement Coverage

Silent Shift: Detecting the Insider Before the Incident

Track 16 — Peace, Justice and Strong Institutions

Not every security threat begins with obvious malicious activity. A compromised or malicious account may behave normally for a long period before gradually or suddenly accessing systems, files, privileges, or resources outside its usual pattern. Individual events may appear low-risk in isolation, but a sequence of small behavioral changes can become significant when viewed together. Security teams therefore need ways to identify meaningful shifts without treating every unusual action as malicious.

Design a behavioral security system that establishes user baselines, detects significant deviations, and helps investigators understand why an account has become suspicious. The system should consider multiple available signals, correlate events over time, account for legitimate contextual changes such as new projects or role changes, and prioritize activity for human investigation. Teams may determine how behavior is represented, how anomalies are combined, how context is incorporated, and how alerts are explained. The objective is early detection of potentially dangerous transitions while controlling false positives.

Requirement Coverage Map

Brief requirement	Where it's addressed
Establish user baselines	Section 7.1 (self-baseline) & 7.2 (peer-cohort baseline)
Detect significant deviations	Section 7.1, 7.2, 7.4 (risk fusion)
Consider multiple available signals	Section 4 (logon, file, email, HTTP, device, LDAP)
Correlate events over time	Section 7.3 (CUSUM drift detection)
Account for legitimate contextual changes	Section 8
Prioritize activity for investigation	Section 11 (ranked queue)
Help investigators understand why	Section 7.6 (explanation layer) & Section 11
Control false positives	Section 9

3. Core Design Philosophy

Five decisions define this system, each closing a specific, documented gap in how insider-threat detection is usually built:

- **Dual baseline, not single baseline** — scoring a user only against their own history is the most common approach in the literature and the weakest — it can't tell "unusual for this org" apart from "unusual for this person," and it can't absorb a legitimate role change gracefully.
- **Context as a refreshed feature, not a retrained model** — role, team, and manager feed the model as live facts, following the design Google's production system (Facade) uses to handle organizational change without retraining the peer/context path. The self-baseline component is refreshed on a slower, separate cadence — see Section 7.5.
- **Explicit drift detection, not just decay** — most implementations decay old events but never formally test whether behavior is on a sustained upward trend. CUSUM does exactly that — the direct technical answer to the brief's "gradually... before suddenly" language.
- **Explanation-first output** — a risk score alone does not satisfy "helps investigators understand why." Every alert is generated together with the plain-English reasoning behind it, down to the specific fallback logic that produced it.
- **Honesty about scope** — the system is built and demonstrated on the CERT Insider Threat Dataset, a recognized academic benchmark, and its limitations (Section 12) are documented rather than hidden.

4. Data Strategy

The CERT Insider Threat Dataset (Carnegie Mellon Software Engineering Institute) is the standard public benchmark for this problem. Release r4.2 provides realistic synthetic logs for 1,000 simulated employees over roughly 18 months, with labeled insider-threat scenarios built in — giving both training data and ground truth for evaluation.

Log files used

File	Contents	Role in the system
logon.csv	Logon / logoff events per workstation	Working-hours baseline, after-hours access flag
file.csv	File open / write / copy / delete, incl. removable media	Exfiltration-pattern signal
email.csv	Send / receive activity, recipients, attachment size	External-recipient and data-volume signal
http.csv	Web browsing, upload / download activity	Cloud-upload / personal-webmail signal
device.csv	USB connect / disconnect events	Physical exfiltration signal
LDAP file	Role, department, manager, employment dates	Peer-cohort construction & context features

Using a recognized, citable dataset instead of invented demo data is a deliberate credibility choice — judges evaluate the detection approach itself, not a synthetic dataset built in the hackathon window.

5. Deployment Model — Where It Lives

Silent Shift is a passive, off-to-the-side analytics layer — not an inline proxy, and not something installed on any employee's device. It does not sit in the path of any traffic, and it never intercepts, modifies, or delays anything a user does. It reads logs that a company's existing systems already generate for other reasons, and IT connects it centrally, once, on a backend server.

What it connects to

Existing company system	What it already logs	Used for
Domain controller / Active Directory	Logon / logoff events, company-wide	Working-hours baseline, self- and peer-baseline input
File server	File open / copy / delete activity	Exfiltration-pattern signal
Email server (Exchange / Office 365, etc.)	Send/receive metadata, recipients, attachment size	External-recipient and data-volume signal
Web proxy / firewall	Upload/download activity, destination categories	Cloud-upload / personal-webmail signal
HR / LDAP system	Role, department, manager, tenure	Peer-cohort construction, context refresh
Existing endpoint security tool (if present)	USB/device connect events	Physical-exfiltration signal, where available
<i>Nothing is installed on any employee's laptop or phone. Setup is a one-time backend connection to systems IT already runs. If Silent Shift is offline, every business system it reads from keeps working exactly as before — it observes, it never participates in the data path.</i>		

This is a deliberate contrast with inline data-loss-prevention tools that intercept traffic directly (proxy-based systems). Those sit in the path and can modify data in transit; Silent Shift only ever reads what already exists, after the fact or as logs stream in, and produces a risk score and explanation for a human — never an automatic action.

6. System Architecture

At its simplest, this is three signals — self-baseline, peer-baseline, and drift — feeding one fusion score and one plain-English explanation. The seven-layer breakdown below is that same idea broken into its buildable pieces, not additional complexity layered on top.

#	Layer	Purpose	Build priority
1	Signal ingestion	Join logon / file / email / HTTP / device logs per user-day; pull role, team, manager from LDAP	Core
2	Self-baseline	Point-anomaly score vs. the user's own history (Isolation Forest)	Core
3	Peer-cohort baseline	Deviation score vs. same-role / same-manager peers, with department-level fallback	Core
4	Context layer	Role / team / manager fed as live features, refreshed daily	Core
5	Drift detection	CUSUM test on the pre-multiplier fused daily score per user	Core
6	Risk fusion	Weighted combination of layers 2, 3 and 5 into one 0–100 score, with multipliers applied after CUSUM's input is taken	Core
7	Explanation + queue	Plain-English "why," ranked investigator queue, feedback loop	Core

Stretch additions (only after the core above is fully working end to end)

- LSTM Autoencoder as a second, sequence-aware self-baseline signal feeding into risk fusion.
- SHAP attribution layered on top of the plain-English explanation for deeper feature-level transparency.
- MITRE ATT&CK tag lookup — a static activity-type-to-technique-ID table, described plainly as a lookup table, not a sophisticated tactic-mapping model.

This sequencing is intentional: a complete, well-explained three-signal system will score better with judges than a five-signal system that is only partially working or whose explanations feel incomplete.

7. Models & Techniques

7.1 Self-Baseline — Isolation Forest

What: an ensemble tree-based anomaly detector that isolates outliers by random recursive partitioning — anomalous points require fewer splits to isolate.

Why chosen: fast to train, robust on modest per-user data volumes, and produces a stable, demoable signal within hours.

Inputs: daily aggregated activity counts and timing features per user (login times, file-access counts, email volume, USB events).

7.2 Peer-Cohort Deviation Scoring

What: group-by statistics (z-score of a user's activity against the mean and spread of their role/manager cohort) rather than a full social graph — the correct-fidelity design for what CERT's LDAP data actually contains (role, department, manager — not meeting or collaboration logs).

Explicit small-cohort fallback:

If a role/manager cohort falls below a minimum size (a small handful of people), the system automatically falls back to comparing against the department-level cohort instead. This fallback is not silent — it is stated directly in the investigator-facing explanation text, e.g.: "Compared against role peers; fell back to department-level comparison because the role cohort had only 3 members." Making the fallback visible, rather than quietly substituting a weaker signal, is itself part of the false-positive-control design.

7.3 Temporal Drift Detection — CUSUM

What: a cumulative sum control chart run over each user's daily risk score, accumulating deviations from an expected baseline and signaling when the cumulative sum crosses a control threshold — the classical statistical tool for a sustained mean shift, as opposed to a single outlier point.

Locked definition — what CUSUM watches:

CUSUM runs on the pre-multiplier fused daily score — the simple combination of the self-baseline and peer-baseline scores, before role/time/sensitivity multipliers (Section 7.4) are applied. Defining this precisely, once, keeps the quantity CUSUM watches stable regardless of how the multiplier weights are tuned later. The raw CUSUM path (the day-by-day accumulating sum, not just a pass/fail flag) is shown directly in the investigator's forensic timeline, so a human can see the gradual accumulation rather than trust an opaque flag.

Why CUSUM over a simpler moving average: an exponentially weighted moving average smooths noise but still needs an arbitrary threshold on the smoothed value; it does not formally test for a meaningful sustained shift. CUSUM does, at only slightly more implementation cost, and maps directly onto the brief's own language.

7.4 Risk Fusion Engine

What: a weighted combination of the self-baseline score, peer-cohort deviation score, and drift signal into one 0–100 risk score, adjusted by contextual multipliers applied after CUSUM's input is computed.

Multiplier	Condition	Effect
Role sensitivity	Admin / privileged account	Higher weight
Time of access	Before 7am or after 8pm	Higher weight
Data sensitivity	Confidential-tagged resource, removable media	Higher weight
Score decay	Each day without new anomalous activity	Gradual weight reduction

7.5 Self-Baseline Refresh Cadence

The Isolation Forest self-baseline is trained on a rolling window of each user's own history and is not continuously retrained on every event. Within the CERT-scenario demo timeframe (days to weeks) this is not a limitation. In a longer-running real deployment, the self-baseline would need periodic refresh — e.g. monthly — so that a person's own legitimate long-term habits don't eventually read as permanent anomalies. This is stated here as a scoped, acknowledged design boundary of the MVP, not an oversight; it is distinct from the context/peer path in Section 8, which updates immediately and needs no such refresh cycle.

7.6 Explanation Layer

What: a templated natural-language generator that composes the alert text directly from the fusion inputs, e.g.: "Flagged: activity is unlike this user's own 90-day history (self-baseline), unlike their peer cohort's typical pattern — compared against role peers; fell back to department because the role cohort was too small (peer-baseline) — and has trended upward for 9 consecutive days (drift)."

Why this over a SHAP plot alone: SHAP explains a model's internals to someone who understands the model. The brief asks the system to help an investigator understand why an account is suspicious — a plain-language requirement satisfied by this templated layer, not by SHAP values behind it. SHAP (Section 7.8) is a supplementary layer, not a substitute.

7.7 [Stretch] Sequential Self-Baseline — LSTM Autoencoder

What: a compact 2-layer LSTM Autoencoder (hidden size 32) trained on each user's sequence of daily activity; high reconstruction error signals a session that doesn't fit the user's learned temporal pattern.

Why stretch, not core: it adds real value but is the highest-effort, highest-convergence-risk component on a hackathon timeline. Added only once the core three-signal system is fully working, so a training issue never costs a working demo.

7.8 [Stretch] SHAP Attribution

A supplementary, more granular layer under the plain-English explanation — useful for a deeper-diver judge question, not the primary investigator-facing artifact.

8. Handling Legitimate Context Changes

Role, team, manager, and tenure are pulled from the LDAP/HR feed and refreshed daily. When any of these change:

- The user's peer cohort is recomputed immediately against the new role or manager group.
- The self-baseline (Isolation Forest trained on the user's own history) is left unchanged — organizational moves do not rewrite personal history.
- Peer-deviation is therefore measured against people who look like the user's current role, so behavior that is normal for the new context is not treated as anomalous.

This follows the same principle used in production systems such as Google's Facade: organizational context is an explicit, observable input rather than something the model must relearn. No model retraining is required for role or team changes. (The self-baseline itself can be refreshed on a longer periodic schedule if a user's legitimate personal patterns drift substantially over many months — see Section 7.5; within the timeframe of the CERT scenarios this refresh is unnecessary.)

9. Controlling False Positives

Alert fatigue is the documented, specific reason UEBA deployments fail in practice — industry data shows security analysts ignoring a substantial share of daily alerts, with average dwell times measured in months. Four mechanisms work together to keep alert volume low and signal quality high:

- **Ensemble requirement** — an alert is raised only when multiple signals (self-baseline, peer-cohort, or drift) agree. A single noisy day is suppressed.
- **Peer-relative scoring** — behavior unusual for the org at large but normal for a specific role or cohort is not flagged, because the comparison point is the cohort, not a global norm — and the fallback to department-level comparison is stated explicitly when it happens (Section 7.2).
- **Sustained-drift testing** — CUSUM requires a meaningful upward trend across multiple days, not a single outlier. One-off spikes (deadline periods, temporary projects) do not cross the control limit.
- **Analyst feedback loop** — every case in the investigator queue carries a "mark as false positive" action. Confirmed false positives down-weight that specific signal combination going forward — a lightweight, demoable form of human-in-the-loop calibration.

Together these convert raw anomaly scores into a short, ranked queue an investigator can actually work.

10. Data Governance & Responsible Use

This system observes employee behavior, which is a real responsibility, not just a technical design question — especially under a track explicitly about strong institutions. The design choices below exist to keep the tool accountable to the same standard it's meant to enforce.

- **Data minimization** — the system reads activity metadata — timestamps, event types, categories, sizes — not full content. It reads that an email was sent externally with a large attachment, not the email's body text; that a file was copied, not the file's contents.
- **Retention limits** — raw log data is retained only for a configurable window (e.g. 90 days); only aggregated risk-trend data persists longer, for the drift analysis itself to remain meaningful over time.
- **Access is itself audited** — every time an investigator opens a case or queries an individual's risk score, that access is logged — who looked at whose data, and when. The tool that watches for misuse is not exempt from being watched itself.
- **No covert monitoring** — the existence of the system is disclosed to employees (e.g. via company policy/handbook), even though they never interact with it directly — consistent with standard employee-monitoring disclosure norms in most jurisdictions, including India's DPDP Act and comparable regulations elsewhere.
- **Human-in-the-loop, never autonomous action** — the system never blocks, restricts, or takes any action against a user automatically. It is a watching layer, not a locked door — every flagged case is a recommendation to a human investigator, who makes the actual decision.

This section is a design commitment, not a legal compliance guarantee — an actual deployment would need review by qualified legal/compliance counsel in the relevant jurisdiction before production use.

11. Investigator Experience & Demo Walkthrough

Only the security/IT investigator ever opens this system — employees never see it, log into it, or interact with it. The tool never blocks or restricts anyone; it only raises a flag for a human to review and decide on.

Dashboard components

- **Ranked risk queue** — all users sorted by fused risk score, with severity tiers (Medium / High / Critical).
- **"Why this account now" panel** — the templated explanation, broken into self / peer / drift, including the fallback disclosure when relevant, shown the moment a case is opened.
- **Forensic drill-down timeline** — the specific sequence of events that drove the score, in chronological order, including the raw CUSUM accumulation path.
- **Feedback control** — a single "false positive — expected because..." action visible on every case.

Demo strategy

Rather than relying on an abstract, illustrative scenario alone, the live demo is anchored to one or two specific, pre-identified labeled insider scenarios from CERT r4.2, walked through end-to-end against real ground truth. This makes the "why this account now" panel verifiable in the room, not just plausible on a slide — the single highest-leverage improvement identified during review of this specification.

Representative pattern this kind of case follows: an employee's file-access and removable-media activity drifts upward over roughly two weeks, culminating in a burst of file copies to a USB device shortly before end of shift, with names matching a sensitive-data pattern. No single action looks alarming — only self-baseline, peer-baseline, and drift together reveal it, which is exactly the walkthrough that demonstrates every explicit requirement in the brief in one narrative.

12. Known Limitations & Residual Risks

Stated plainly, not to undersell the system, but because a tool's credibility rests as much on what it acknowledges as on what it claims.

Inherent to this approach — managed, not eliminated

- **Slow, disciplined evasion** — behavioral anomaly detection, by definition, only catches behavior that deviates. An attacker who moves slowly and stays close to peer-group norms may not trigger drift or peer-deviation at all. This is a property of the entire category of behavioral detection, not unique to this implementation.
- **Collusion** — peer-cohort scoring compares a person against their peer group; if multiple people in the same cohort drift together, their shared behavior can look mutually normal against each other. Coordinated multi-person collusion is not specifically detected by the current design.
- **Small-cohort fragility** — the department-level fallback (Section 7.2) narrows this problem but does not eliminate it — a department of 3–4 people still isn't a statistically solid baseline.
- **Heuristic fusion weights** — the multipliers in Section 7.4 are a reasoned design choice, not a formally calibrated probability. A rigorous answer to "why is the threshold 60 and not 55" requires a validation pass against labeled outcomes — a documented next step, not a claim already made.

Execution-dependent — to be validated by running the system

- **CUSUM tuning** — the exact threshold and slack values need real tuning against CERT data to confirm they distinguish genuine drift from seasonal or deadline-driven spikes. Not yet validated at time of writing.
- **Explanation clarity** — the plain-English panel has not yet been tested on a reader outside the immediate team.
- **Live integration risk** — the standard hackathon risk of a multi-part system not being fully wired together in time — managed by building and verifying the core three-signal system first, before any stretch component is added (Section 6).

Scope and dataset boundaries

- **CERT's age and setting** — r4.2 reflects a mid-2010s Windows-domain office environment. Modern exfiltration increasingly happens via cloud storage, SaaS platforms, and messaging apps rather than removable media. The architecture (signals → baselines → fusion → explanation) generalizes to any structured activity log; the specific demo is bound to what CERT actually contains.

13. Technology Stack

Layer	Technology
Data processing	Python, Pandas / Polars
Core ML	scikit-learn (Isolation Forest), NumPy/SciPy (CUSUM)
Stretch ML	PyTorch (LSTM Autoencoder), SHAP
Backend API	FastAPI
Frontend	React + Recharts (or similar charting library)
Packaging	Docker / Docker Compose for one-command demo setup

14. Business Model

Buyer, user, and secondary approver — three different people

Role	Who they are	What they care about
Economic buyer	CISO / IT Director (SMB); Chief Risk/Compliance Officer co-signs in regulated industries	Reducing breach risk; satisfying a client audit requirement
Day-to-day user	SOC analyst, or a named Insider Threat Program owner	A queue they can act on without drowning in noise
Secondary approver	HR + Legal	Sign-off is required because this monitors employees — no HR/Legal approval, no deal, in most real organizations

The beachhead — a specific first market, not "any company"

- Indian mid-market IT/ITES/BPO companies (roughly 500–5,000 employees) — handle sensitive client data, increasingly required by Western clients' audits (SOC 2 / ISO 27001) to prove insider-threat monitoring, and priced out of enterprise-tier UEBA contracts.
- Global Capability Centers (GCCs) — India-based back-office arms of foreign banks/companies, facing global compliance pressure on local budgets.
- Indian fintech/NBFC mid-market — RBI-driven security expectations, high sensitivity of financial data.

The same underserved-mid-market pattern holds anywhere labor-intensive outsourcing or regulated data handling meets budget-constrained security — Eastern Europe's BPO sector and Southeast Asian shared-services hubs face the same audit pressure and the same coverage gap. India is the concrete first beachhead here, not the ceiling of where this applies.

Why they buy now — the trigger, not just the need

- A new enterprise client's security due-diligence questionnaire asks "do you monitor for insider threats?" and the honest current answer is no.
- A near-miss or actual incident just happened — the single biggest real-world purchase trigger in this category.
- Regulatory pressure (e.g. India's DPDP Act) raises the bar on "reasonable security practices" for any organization handling personal data.

Revenue streams

- **Core SaaS subscription** — priced per monitored employee/month — SMB self-serve tier and a custom-contract enterprise tier (VPC/on-prem option for regulated industries).
- **Compliance & audit reporting** — sells to the Compliance/Legal buyer inside an account already landed via Security — expansion revenue, not new-customer acquisition cost.
- **Managed monitoring tier** — for SMBs with no dedicated security staff — we operate the tool and send a digest instead of expecting them to run a SOC dashboard themselves.
- **Integration / professional services** — one-time SIEM/HR-system hookup fee at the enterprise tier — the foot in the door for the larger annual contract.

Land-and-expand

Land with Security (core detection + dashboard) → expand to Compliance/Legal (audit reporting module) → expand seat count as the company grows → cross-sell managed monitoring to smaller subsidiaries or sister companies in the same group.

Positioning, pitch-ready

We are not trying to displace Securonix, Exabeam, or Splunk at their existing large-enterprise accounts. We are targeting the large segment of mid-market companies that currently use nothing at all — particularly Indian IT/ITES/BPO firms, Global Capability Centers, and regulated fintechs, with the same underserved-mid-market pattern holding anywhere labor-intensive outsourcing or regulated data handling meets budget-constrained security.

These organizations are contractually asked by Western clients whether they monitor for insider threats; the honest answer today is often no. Our system lands with the CISO or IT Director on a per-employee subscription, expands into compliance/audit reporting for Legal and Risk, and offers a managed monitoring tier for smaller firms with no dedicated SOC. The context-as-feature design reaches useful output faster than tools requiring long baseline retraining periods — the practical reason a mid-market buyer chooses us over an enterprise incumbent they cannot afford or staff.

In the live pitch, keep this section brief — the technical execution and the live "why this account" walkthrough carry more weight with judges. Use the positioning paragraph above to answer "who pays and why" cleanly, then return to the system.

15. Build Roadmap (Hackathon Timeline)

Phase	Hours	Deliverable
1. Data + cohorts	0–8	CERT r4.2 ingested; logs joined by user-day; role/manager/department cohort tables built; 1–2 labeled insider cases pre-identified for the demo
2. Core detection	8–20	Isolation Forest scoring + peer-cohort z-score deviation (with department fallback), both producing stable output
3. Drift layer	20–28	CUSUM running on the locked pre-multiplier fused score; context refresh wired to cohort membership
4. Fusion + explanation	28–36	Risk fusion engine; templated plain-English explanation including fallback disclosure
5. API + dashboard	36–44	FastAPI backend; ranked queue, drill-down timeline (with raw CUSUM path), feedback button
6. Polish + stretch	44–48	MITRE tag lookup; LSTM/SHAP added only if core is fully stable; pitch deck; governance section finalized

16. Pre-Submission Checklist

- ☐ Run the actual models on CERT data; record real precision/recall/false-positive numbers — do not rely on other papers' reported accuracy.
- ☐ Peer-cohort fallback implemented in code AND stated explicitly in the explanation text (Section 7.2).
- ☐ CUSUM's input formally locked as the pre-multiplier fused score (Section 7.3); raw CUSUM path visible in the forensic timeline.
- ☐ Self-baseline refresh caveat included in the write-up (Section 7.5) — already drafted here.
- ☐ 1–2 specific labeled CERT insider cases pre-selected; demo narrative built and rehearsed around them (Section 11).
- ☐ Explanation panel drills down to real event-level detail, not just the three signal names.
- ☐ Data governance section finalized and ready to present if asked (Section 10) — already drafted here.
- ☐ MITRE ATT&CK and LSTM/SHAP confirmed as true stretch — only added after the core three signals are fully working.
- ☐ Business model kept concise in the live pitch; full depth lives in this document (Section 14).
- ☐ Team aligned on talking points for known limitations (Section 12) — stated calmly and proactively if asked, not discovered mid-Q&A.

17. Why This Approach Wins

- **Judge comprehension** — insider threat / UEBA is a concept judges already have a mental model for — no domain tutorial needed before they can evaluate the solution.
- **Feasibility to the exact spec** — every explicit line in the brief maps to a specific, built component (Section 2's coverage table).
- **Approach quality** — the design mirrors a disclosed, running production system (Google's Facade) and peer-reviewed ensemble research, not a hackathon-original architecture with no track record.
- **Institutional integrity, not just detection** — under a track literally about strong institutions, the system documents its own data-governance commitments (Section 10) rather than being purely extractive of employee data.
- **Business model** — grounded in cited market figures and a specific, defensible beachhead rather than a generic "we'll sell to enterprises" pitch.
- **Says what it doesn't know** — a system that states its own limitations clearly (Section 12) is more credible to a technical judge than one that claims perfection.

18. Future Roadmap (Beyond the Hackathon)

- Full implicit social-graph peer modeling (meeting co-attendance, code-review activity) once richer collaboration data is available, beyond what CERT's LDAP file supports.
- Graph-based multi-user correlation to address the collusion blind spot identified in Section 12.
- Seasonality-aware CUSUM — detrending for known cyclical business periods (quarter-end, launch weeks) before applying the drift test.
- Managed-SOC tier for SMB customers without an in-house security team.
- Formal legal/compliance review of the data-governance model (Section 10) ahead of any production deployment.

19. Research Basis & References

This specification's design choices are grounded in the following sources:

- CERT Insider Threat Dataset — Carnegie Mellon University Software Engineering Institute (releases r4.2 / r5.2 / r6.2).
- Kantchelian, Neo, Stevens, Kim, Fu, Momeni, Huber, Bursztein, Pavlidis, Buttpitiya, Cochran, Poletto — "Facade: High-Precision Insider Threat Detection Using Deep Contextual Anomaly Detection," Google, arXiv:2412.06700 (also presented at Black Hat USA 2025).
- Pratibha, Wang, Aggarwal, Ji, Tay — "Learning Correlation Graph and Anomalous Employee Behavior for Insider Threat Detection," Nanyang Technological University.
- AIB-ITD hybrid ensemble framework (Isolation Forest + PCA + LSTM Autoencoder + SHAP + Automated Response and Privilege Containment), evaluated on the SEI/CMU CERT dataset — DOI: 10.3390/computers15070426.
- Exabeam Security Research — peer-based prediction of first-time resource access to reduce false-positive rates.
- kruxshnx/UBA-Insider-Threat-Detection — open-source reference implementation (LSTM Autoencoder + Isolation Forest + contextual risk scoring, FastAPI + React), used to validate hackathon-scale build feasibility.
- Splunk Security Research and Proofpoint Insider Threat Management — industry data on SOC alert fatigue and false-positive rates in deployed UEBA systems.
- Market sizing: insider threat management and UEBA market forecasts (QKS Group; industry market research, 2026 editions), Ponemon Institute 2025/2026 cost-of-insider-risk figures.